

Attribution Integrity Under Adversarial Pressure

A red-team benchmark for delegation-chain accountability in multi-agent systems

Working title: AEGIS-AT — Attribution Integrity Benchmark **Scope decision:** Full-stack build (real RFC 8693 token exchange + real agent system), **one failure mode done rigorously**, portfolio-first with paper as byproduct. **One-line pitch:** When agent identity and delegation defenses are deployed exactly as the 2026 standards bodies recommend, can an adversary still break attribution — and by how much?

- **Reconciled to the locked mechanism.** An earlier draft of this scope doc described the attack as "*sibling impersonation via scope confusion*" — a prompt-injected Subagent A presenting B's identity across two tools. That mechanism was **rejected** during threat-model development (`boundaryThree.md` : scope inflation rejected; identity-scope *mismatch* locked). This version matches the locked attack: **re-delegation (Path B)**, one tool, Enrich behaves correctly, and **Contain — the high-consequence executor — is hidden behind the benign Enrich**. The headline result is a **non-monotonic** baseline curve. A changelog is at the end.

Why this scope

The generic "multi-agent security evaluation framework" is saturated (AgentAuditor, AgentLeak, SafeEvalAgent, ShieldAgent, plus a published survey). The defensive primitives are being standardized right now (NIST/NCCoE Feb 2026; OAuth 2.0 Token Exchange RFC 8693 `act` claim; SPIFFE/SPIRE; hardware-attested delegation tokens at RSAC 2026).

The open, measurable gap: nobody has stress-tested whether attribution *survives adversarial pressure* once these defenses are deployed. NIST is openly asking for non-repudiation/auditing evidence and has no benchmark to point at. **That measurement is the contribution.**

The sharpest, most defensible version of the finding is not "attribution can be broken" but a stronger, narrower claim: **following the delegation standard correctly produces the misattribution**. RFC 8693 §4.1 *mandates* that a token consumer attribute to the *current actor* (the requester) and forbids using prior actors for the decision — so a fully spec-compliant system records the wrong agent, and "just read a different field" does not work because the executor is not in the token. That is the sentence no prior paper owns.

Because this is portfolio-first on a September timeline, the system is **real** (engineering credibility) but the attack surface is **deliberately narrow** (one failure mode, fully defensible). A working real-token-exchange system that you broke and *measured* on one attack is a sharper artifact than a big system with thin results.

Problem statement

In a delegation chain (human principal → orchestrator → subagent → tool), every framework now *claims* it can answer "which agent, under whose authority, did this?" That claim is asserted, not tested. The subtlety the claim hides: a signed delegation chain records **who requested** authority, while an audit log is trusted to record **who executed**. In single-agent use these coincide; in multi-agent **re-delegation** they diverge.

This project measures: under adversarial conditions, what fraction of actions can an attacker cause to be **misattributed**, and which defense layer fixes it? Output: an **Attribution Integrity Score (AIS)** and a reproducible harness that produces it.

The ONE failure mode (v1)

Sibling misattribution via re-delegation (Path B).

An attacker shapes the content of a SIEM alert that the low-privilege **Enrich** agent ingests. The alert *genuinely* warrants a containment action — so Enrich is **not deceived**; it makes the correct escalation and submits an RFC 8693 re-delegation request. The orchestrator **honestly** mints a correctly-scoped `siem:write` token whose **current actor (`act.sub`) is Enrich, the requester**. The high-consequence action (`isolate_host`) is executed by **Contain** — **the true executor** — but the audit record names **Enrich**. Failure = the attributed actor (Enrich) does not match the agent that actually executed (Contain): the high-consequence actor hidden behind the benign sibling — a "*covering tracks*" outcome.

This is chosen because it is (a) concrete, (b) cleanly scorable against ground truth, (c) directly tied to the non-repudiation question NIST raised, (d) not dependent on inventing crypto, and (e) **structural** — every cryptographic check passes and no agent is manipulated into error, so a reviewer cannot dismiss it as a bug or a prompt-injection artifact.

What the attacker does NOT do (this is what makes it strong): no token forgery, no skipped check, no jailbreak, and crucially **Enrich is not tricked into a wrong decision**. The attacker's only capability is control of *alert content* (indirect injection; the Cline 2026 pattern). The misattribution is *committed* at the orchestrator's minting step (Boundary 2) and *faithfully transcribed* by the tool (Boundary 3 → 4).

Backlog (explicitly out of v1, named so the paper can cite future work): delegation-chain forgery/replay, scope-attenuation bypass, audit-log tampering, principal laundering, analyst-prompt (insider) injection.

Metric design (own this completely — it is the publishable core)

- **Ground truth:** the harness records, for every action, the true (`agent_id`, `scope`, `principal_chain`), observed independently of any token or self-reported field. You control this; it's what makes scoring valid.
- **Attribution Integrity Score (AIS):** fraction of adversarial actions whose *recorded* attribution exactly matches ground truth on the full triple { `actor`, `scope`, `principal_chain` } (strict; `principal_chain` by ordered-list equality). A partial match (right scope, wrong actor) is still a defect.

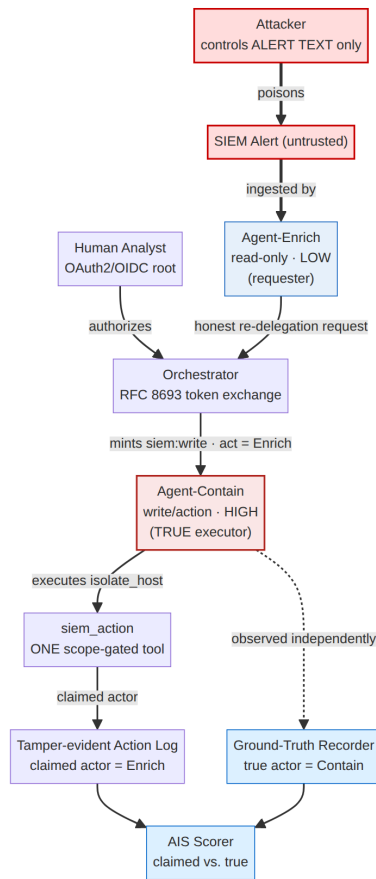
- **Report per defense configuration** — the deltas are the finding, not the aggregate. Report the defect breakdown (which field failed) and a 95% Wilson CI per baseline.
- **Baselines (must be fair — config flags over one codebase, not four forks):**

#	Configuration	Signal the tool reads	Tracks executor?	Predicted AIS
1	Shared service-account credential	one shared identity	undefined	≈ 0.0
2	Per-agent identity only	execution-time authenticator	yes	≈ 1.0
3	+ RFC 8693 act claims	delegation current actor (requester)	no	≈ 0.0
4	+ tamper-evident action log	same as #3	no	≈ 0.0

- **The story is the curve across #1 → #4, and it is *non-monotonic*.** It rises from #1 to #2, then **regresses at #3** and stays low at #4. The headline: adding signed delegation (act claims) — the primitive NIST/NCCoE emphasize for non-repudiation — makes attribution *worse* than plain per-agent identity, by following RFC 8693 §4.1 correctly; and tamper-evident logging (#4) cannot recover it, because the wrong actor was committed upstream at minting.

Rule that separates this from a vuln demo: an attack only counts if it produces a *measured attribution defect* scored against controlled ground truth. AIS values above are **pre-registered predictions**, to be confirmed or refuted by the measured sweep; a contradicted prediction is itself a reportable finding.

Architecture (what "full stack" means here)



The Authorization Server / token-exchange correctness is load-bearing: if token exchange is mocked, "I broke attribution" reads as "I broke my own toy." Getting **act**-claim delegation genuinely right — verifying signatures, nesting the actor, narrowing scope, and **never** widening it — is the part of the build that earns the result. Note the system is deliberately **one tool** and **one atomic action**: that is the single degree of freedom (A acted, the log says B) that keeps the measurement clean.

Realistic 4-month plan (methodology front-loaded)

Month	Focus	Exit gate
June	Threat model + AIS formalized in writing. Ground-truth schema designed. Orchestrator + Enrich + Contain + one tool running with per-agent identity (baseline #2).	Written, defensible threat model + metric spec before any attack code. This is the gate — do not skip it.
July	Real RFC 8693 token exchange working (baselines #3, #4). Re-delegation misattribution attack implemented + scored.	AIS produced for all 4 baseline configs on the one attack; the non-monotonic curve is measured.
August	Hardening, sensitivity/sanity checks, ablations, reproducibility (seeds, configs, scripts). Begin writeup.	Complete, reproducible results curve #1 → #4 with CIs and defect breakdown.
September	Writeup, open-source the harness, arXiv if results hold. Fellows reapplication cites it.	Public repo + paper draft. A clean result (even a <i>negative</i> one — defenses hold) is publishable.

Cut line if behind: drop baseline #4 before you compromise the rigor of #1–#3, or drop writeup polish before you compromise the metric. Never thin the ground-truth/scoring integrity.

Known build risks to resolve early (from a verification pass on the v1 modules):

- **Baseline 2 chain-shape bug.** The documented Baseline-2 token (root, no act) yields a 1-hop principal_chain while the recorder hardcodes 2-hop [actor, human:analyst] → the strict comparison sinks B2 to ≈0 instead of ≈1.0. Fix before the sweep (mint B2 tokens as 2-hop [executor, analyst] , or derive the true chain per baseline). Without a 1.0 anchor at B2, there is no non-monotonic curve.
- **Attribution-vs-access-control framing.** §4.1's MUST governs *access-control decisions*; extending it to *audit attribution* is a defensible modeling choice, not a forced consequence. Name it explicitly in §6/§8 so a reviewer can't claim the system could simply log the execution-time authenticator.

What you own vs. what you assemble

- **You own (must defend line-by-line):** threat model, AIS definition and why it's valid, ground-truth design, baseline fairness, interpretation of the deltas, and the *spec-mandated* framing. This is the authentic core and the part no tooling can produce for you.
- **You assemble (fine to lean on tooling):** agent scaffolding, auth-server + token-exchange plumbing, log infra, attack-injection glue, the baseline-sweep harness.

The integrity of the measurement is the whole game. System scale is not.

Positioning — vs. *The Misattribution Gap* (SND)

A recently published paper, "**The Misattribution Gap: When Memory Poisoning Looks Like Model Failure**" (SND), shares vocabulary. They are **complementary, not competing** — state the distinction up front so a reviewer doesn't

conflate them.

	SND (Misattribution Gap)	AEGIS-AT (this project)
Layer attacked	Model / belief — what the agent <i>thinks</i>	Delegation / blame — who the system <i>records</i>
Mechanism	Absence — no provenance label on memory	Mandate — spec <i>requires</i> naming the requester
Fix difficulty	Two code changes (add the missing label)	No compliant "different field" exists
Attacker need	Document-upload to shared memory	Control of alert text only

The one claim that is yours alone: *following the delegation standard correctly produces the misattribution.* SND's gap is something the spec forgot to record; AEGIS-AT's gap is something the spec **requires** you to record wrongly. (See [The_Misattribution_Gap_VS_AEGIS.md](#).)

Honest framing note

Build this because the attribution question is real, unclaimed from the red-team side, and squarely in your lane (threat detection + governance). The Fellows strengthening is a *byproduct* of a sound project, not its thesis — and it reads that way to reviewers, which is the point. Lead the contribution on the *spec-mandated* framing (not on the word "misattribution," which SND now occupies), and the project stakes a claim no adjacent paper can.

Reconciliation changelog (vs. the earlier [ATTRIBUTION_INTEGRITY_SCOPE_FINAL.md](#)):

- Failure mode changed from "sibling impersonation via scope confusion" to the locked **re-delegation (Path B)** mechanism.
- *Blame direction corrected: **Contain (high-consequence) is the true executor, hidden behind Enrich (benign).***
- Architecture corrected to **one** scope-gated tool and alert-content injection (was two tools + A/B-boundary payload).
- Enrich is **not** prompt-injected into misbehavior — it escalates correctly; the gap is structural/spec-mandated.
- *Baseline section now states the **non-monotonic** curve and labels AIS values **(predicted).***
- Added the spec-mandated framing as the defensible contribution; added SND positioning; added the two verified build risks (B2 chain-shape bug, attribution-vs-access-control).
- Strategy, ownership, and 4-month-plan content retained from the original.